

Table of Contents

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

CYBERSECURITY, PRIVACY & COMPLIANCE SERIES

CIS Controles de Seguridad Crítica v8.1

**** Aplicación práctica, medición, evidencia y herramientas de código abierto****

Un manual de trabajo para administradores, analistas junior, estudiantes, cambiadores de carrera, asesores y equipos de seguridad

Alberto (Al) Leiva

Primera edición • Julio 2026

Inside: 18 Controles • 153 Salvaguardias • IG1, IG2, IG3 • medición • evidencia • herramientas • manual de gestión • laboratorios • preparación de la carrera |

| ... |

Publication and Use Notice

Autor: Alberto (Al) Leiva

Edición: Primera edición, Julio 2026

Este manual educativo independiente no es un Centro para la publicación, certificación, acreditación, informe de auditoría, opinión legal o garantía de seguridad o cumplimiento. Controles CIS y CIS Los parámetros son marcas comerciales del Centro de Seguridad de Internet. Utilice los recursos oficiales CIS para el contenido exacto y la orientación actual.

Los controles CIS son las mejores prácticas de ciberseguridad. No reemplazan las leyes, reglamentos, contratos, requisitos sectoriales, evaluación de riesgos o responsabilidad de gestión aplicables. Un mapeo muestra relaciones; no prueba automáticamente el cumplimiento de otro marco.

Uso ético y autorizado

Utilice herramientas técnicas únicamente en activos, redes, aplicaciones, cuentas de nube, repositorios y datos que posee o está específicamente autorizado por escrito para evaluar. Use información sintética y sistemas aislados en laboratorios.

Prefacio

Una introducción práctica para priorizar la defensa cibernética y la medición basada en evidencia.

Los Controles CIS convierten las necesidades defensivas comunes en salvaguardias focalizadas. Su fuerza es la priorización práctica: saber lo que posee, controlar software y datos, asegurar configuraciones e identidades, gestionar vulnerabilidades y registros, prepararse para perturbaciones y ataques, y probar si las defensas funcionan.

La versión 8.1 es la edición actual. Se trata de una actualización iterativa al v8 que realineó mappings to NIST CSF 2.0, definiciones ampliadas de plazo reserva, clases de activos revisados y cartografías de Salvaguardia, problemas menores corregidos, aclarar algunas Salvaguardias, e incorporar la función de seguridad de Govern en las cartografías. Los 18 Controles y 153 Salvaguardias siguen siendo la estructura central.

Una instalación de herramientas no es la implementación. La aplicación efectiva requiere un alcance definido, poblaciones completas, configuración segura, pruebas operativas, propietarios capacitados, manejo de excepciones, medición, corrección y retesting. Los administradores deciden prioridades y recursos; los analistas hacen que esas decisiones sean fiables mediante inventarios y pruebas precisos.

Cómo utilizar este manual

- Los administradores deben comenzar con los Capítulos 1-5 y 24–25.
- Los analistas juniores deben estudiar los 18 capítulos de Control, método de medición, herramientas, laboratorio y capítulo de entrevista.
- Los equipos técnicos deben conectar cada Salvaguardia a activos, datos, propietarios, procedimientos, configuración, monitoreo, manejo de excepciones y pruebas.
- Los evaluadores deben utilizar la Evaluación oficial de Controles CIS Especificación de insumos, operaciones, medidas, métricas, suposiciones y exámenes de procedimiento.

Contenido de la palabra:** Este documento contiene un campo de mesa de contenido de Word nativo. La guía del capítulo contendrá números de página verificados para esta edición. Después de editar, haga clic con el botón derecho en el contenido y elija el campo de actualización, luego actualice la tabla completa. |. |

Tabla de contenidos

[Notificación de publicación y uso \[2\]\(#publication-and-use-notice\)](#)

[Uso electrónico y autorizado \[2\] \(#ethical-and-authorized-use\)](#)

[Prefacio \[3\] \(#preface\)](#)

[Cómo utilizar este manual \[4\]\(#how-to-use-this-manual\)](#)

Tabla de contenidos [4](#table-of-contents)

1. CIS Controls v8.1 Foundations [7](#cis-controls-v8.1-foundations)

2. Grupos de aplicación y prioridades [8](#implementation-groups-and-prioritization)

3. Gobernanza, alcance y propiedad [9](#governance-scope-and-ownership)

4. Medición con la Evaluación de CIS Especificación [10](#measurement-with-the-cis-assessment-specification)

5. Implementation Roadmap [11](#implementation-roadmap)

6. Control 1 - Inventario y Control de Activos Empresarios [12](#control-1-inventory-and-control-of-enterprise-assets)

7. Control 2 — Inventario y control de activos de software [13](#control-2-inventory-and-control-of-software-assets)

8. Control 3 — Data Protection [14](#control-3-data-protection)

9. Control 4 — Configuración segura de activos y software de la empresa [16](#control-4-secure-configuration-of-enterprise-assets-and-software)

10. Control 5 — Account Management [18](#control-5-account-management)

11. Control 6 — Access Control Management [19](#control-6-access-control-management)

12. Control 7 - Gestión continua de la vulnerabilidad [21](#control-7-continuous-vulnerability-management)

13. Control 8 — Audit Log Management [23](#control-8-audit-log-management)

14. Control 9 — Email and Web Browser Protections [24](#control-9-email-and-web-browser-protections)

15. Control 10 — Malware Defenses [25](#control-10-malware-defenses)

16. Control 11 — Data Recovery [26](#control-11-data-recovery)

17. Control 12 — Network Infrastructure Management [27](#control-12-network-infrastructure-management)

18. Control 13 — Network Monitoring and Defense [28](#control-13-network-monitoring-and-defense)

19. Control 14 — Security Awareness and Skills Training [30](#control-14-security-awareness-and-skills-training)

20. Control 15 — Service Provider Management [31](#control-15-service-provider-management)

21. Control 16 — Application Software Security [32](#control-16-application-software-security)

- 22. Control 17 — Gestión de la respuesta de incidentes [34] (#control-17-incident-response-management)
- 23. Control 18 — Penetration Testing [36](#control-18-penetration-testing)
- 24. Open-Source Tools [37](#open-source-tools)
 - 24.1 CIS Controls Navigator [37](#cis-controls-navigator)
 - 24.2 CIS Controls Assessment Specification [37](#cis-controls-assessment-specification)
 - 24.3 CIS-CAT Lite [37](#cis-cat-lite)
 - 24.4 CISO Assistant [38](#ciso-assistant)
 - 24.5 Wazuh [38](#wazuh)
 - 24.6 osquery [38](#osquery)
 - 24.7 OpenSCAP [38](#openscap)
 - 24.8 Lynis [38](#lynis)
 - 24.9 Nmap [39](#nmap)
 - 24.10 Greenbone Community Edition [39](#greenbone-community-edition)
 - 24.11 Trivy [39](#trivy)
 - 24.12 OWASP ZAP [39](#owasp-zap)
 - 24.13 Suricata [39](#suricata)
 - 24.14 Keycloak [39](#keycloak)
 - 24.15 DefectDojo [40](#defectdojo)
 - 24.16 Velociraptor [40](#velociraptor)
- 25. Manual de los Controles CIS para gerentes [41](#managers-cis-controls-playbook)
- 26. Guía de la carrera de analista junior [42](#junior-analyst-career-guide)
 - 26.1 Trabajo junior típico [42](#typical-junior-work)
- 27. Laboratorio de Ficción y Cartera [44](#fictional-laboratory-and-portfolio)
- 28. Plan de aprendizaje de 30 días [45] (#thirty-day-learning-plan)
- 29. Preparación de entrevistas [46](#interview-preparation)
 - 29.1 ¿Cuáles son los controles CIS? [46](#what-are-the-cis-controls)
 - 29.2 ¿Qué es IG1? [46](#what-is-ig1)
 - 29.3 ¿Se ajusta IG1 a cada requisito? [46](#does-ig1-fit-every-requirement)

29.4 ¿Cómo mide una Salvaguardia? [46](#how-do-you-measure-a-safeguard)

29.5 ¿Por qué son importantes los inventarios? [46](#why-are-inventories-important)

29.6 Vulnerability scan versus penetración test? [46](#vulnerability-scan-versus-penetration-test)

29.7 ¿Una asignación marco demuestra el cumplimiento? [46](#does-a-framework-mapping-prove-compliance)

29.8 ¿Qué puede concluir un analista junior? [46](#what-can-a-junior-analyst-conclude)

29.9 Preguntas para hacer al empleador [46](#questions-to-ask-the-employer)

30. Plantillas, Glosario, Índice y Referencias [48](#templates-glossary-index-and-references)

30.1 Documentos de trabajo de medición de seguridad [48](#safeguard-measurement-workpaper)

30.2 Registro de hallazgos y nuevas pruebas [48](#finding-and-retest-record)

30.3 Glosario [48](#glossary)

30.4 Índice de asunto [49](#subject-index)

30.5 Referencias oficiales [49](#official-references)

1. Controles CIS v8.1 Fundaciones

La versión actual, estructura, propósito y limitaciones.

“El control organiza 153 Salvaguardias en un programa defensivo práctico” (Nota: 3.94164in”
alt=“Los controles organizan 153 Salvaguardias en un programa defensivo práctico.” /

Figura 1. Los 18 controles de seguridad críticos CIS

- CIS Controls v8.1 fue publicado en junio de 2024 y sigue siendo la edición actual a partir de julio de 2026.
- Los Controles se priorizan las mejores prácticas diseñadas para defender sistemas y redes contra ataques frecuentes.
- El marco contiene 18 Controles y 153 Salvaguardias.
- Las salvaguardias se refieren a las clases de activos, las funciones de seguridad y los grupos de aplicación.
- La versión 8.1 alinea su cartografía NIST CSF a CSF 2.0 e incluye cartografías Govern.
- Existen mapas oficiales para múltiples marcos, pero la aplicación debe verificarse por separado para cada requisito aplicable.

|... | | Control | Resultado defensivo amplio, como inventario de activos o respuesta a incidentes – Salvaguardia | Acción focalizada que puede ser asignada, implementada y medida | Clase de activos | Tipo de tema afectado, tales como dispositivos, software, datos, red, usuarios o documentación Función de seguridad permanente – Govern, Identificar, Proteger, Detectar, Responder o Recuperar la cartografía | Grupo de Aplicación | Priorización recomendada basada en el perfil de riesgo y los recursos Medida de evaluación de la vida útil Entradas, operaciones, medidas, métricas y revisión de procedimientos utilizados para evaluar una salvaguardia sometida

2. Grupos de aplicación y prioridades

Cómo IG1, IG2, y las organizaciones de ayuda IG3 eligen un punto de partida realista.

■img src="media/image2.png" estilo="Ancho:6.15in; Altura:3.39605in" alt="Cada grupo se construye sobre el grupo anterior; IG3 contiene todas las Salvaguardias." /

Gráfico 2 Progresión del Grupo de Aplicación

La situación física Silencioso**

IG1

IG2

IG3

- Cada empresa debe comenzar con IG1 según la orientación CIS.
- Seleccione un IG considerando la sensibilidad de los datos, los servicios críticos, la exposición a amenazas, las obligaciones jurídicas y contractuales, la tolerancia empresarial, la tecnología, la dotación de personal y los conocimientos especializados.
- Un IG es una ayuda de priorización, no permiso para ignorar un riesgo material o requisito obligatorio.
- Adiciones, secuencias, excepciones, aceptación de riesgos, propietarios y fechas.
- Utilice el navegador oficial de control CIS para filtrar v8.1 Salvaguardias y mapas de revisión.

3. Gobernanza, alcance y propiedad

La base de gestión necesaria para que las Salvaguardias funcionen de forma sistemática.

- Definir los objetivos institucionales, los servicios críticos, los datos confidenciales, las obligaciones jurídicas y contractuales, el perfil de amenazas, la tolerancia al riesgo y el Grupo de Aplicación elegido.
- Crear inventarios completos para activos empresariales, software, datos, cuentas, sistemas de autenticación, infraestructura de red, registros, proveedores, aplicaciones y recursos de recuperación.

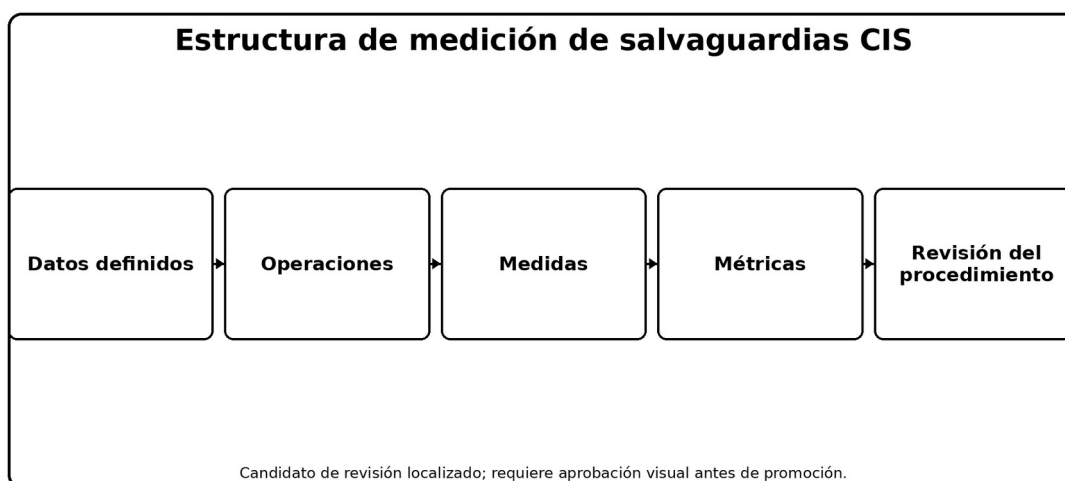
- Assign one accountable owner for each Safeguard and operational owners for each affected platform or process.
- Definir el alcance, la aplicabilidad, las dependencias, las responsabilidades del proveedor de servicios, las excepciones permitidas, la autoridad de aprobación y los desencadenantes de revisión.
- Planificar financiación, personas, habilidades, tecnología, tiempo y gestión del cambio.
- Definir las métricas y la presentación de informes antes de la aplicación para que la cobertura y el fracaso sean visibles.
- Operar un ciclo de gobernanza: priorizar, implementar, medir, corregir, retestar y mejorar.

Rol | Decisión o responsabilidad

|... | – Patrocinador ejecutivo Silencioso Dirección, tolerancia al riesgo, financiación, escalada y rendición de cuentas Silencioso Propietario de control | Diseño de salvaguardias, alcance, procedimiento, medición, excepciones y mejora | Asset o propietario de servicio | Inventario exacto, uso aprobado, configuración, impacto de negocios y remediación TENAS Operaciones de seguridad | Monitoreo, alerta, investigación, respuesta y evidencia TEN IT / Engineering | Implementación, control de cambio, parche, configuración y recuperación TEN GRC / Analyst ANTE Mapping, evidencia, medición, hallazgos, seguimiento de la acción y reportaje | tención Auditoría interna / evaluador tención Servicio prestado | Controles, pruebas, incidentes, cambios y soporte de salida

4. Medición con la especificación de evaluación CIS

Un método repetible para decidir si se aplican salvaguardias.



La especificación oficial pasa de los datos definidos a las operaciones, medidas, métricas y revisión de procedimiento.

Gráfico 3 CIS Estructura de medición de salvaguardias

|** Element** Silencioso** | |... | metadatos de salvaguardia permanente ¿Cuál es la salvaguardia exacta, clase de activos, función de seguridad y IG? TENIENTES DE LAS CUOTAS ¿Qué otras Salvaguardias o poblaciones deben existir primero? | Asunciones | ¿Qué condición aceptada afecta la medición? | ¿Qué datos completos y fiables se requieren? | ¿Qué análisis se debe realizar en las entradas? | | ¿Qué cuentas, listas, fechas, configuraciones o resultados resultan? | TENCIÓN FORMULADA ¿Cómo se calculan e interpretan las medidas? ¿Existe un proceso documentado e incluye elementos necesarios? |

- Definir la salvaguardia exacta y la población abarcada.
- Obtenga los insumos necesarios y valide la integridad, precisión, tiempo, propiedad y fiabilidad de la fuente.
- Siga las operaciones oficiales de medición o documente un método fiable equivalente.
- Retener cálculos de medida y la población de excepción subyacente, no sólo un porcentaje.
- Evaluar si se implementa la Salvaguardia y qué tan bien funciona.
- Asignar una corrección para la cobertura perdida, mala configuración, revisión atrasada, excepciones o datos poco fiables.
- Retesta utilizando los mismos criterios y la población refrescante.
- Report scope, result, exception, limitation, owner, action, and date.

5. Aplicación de la hoja de ruta

Una secuencia práctica de los inventarios a la resiliencia probada.

1. Elija y documente el Grupo de Aplicación inicial y cualquier adición necesaria.
2. Construir y reconciliar las poblaciones principales: activos, software, datos, cuentas, sistemas de autenticación, red, proveedores, aplicaciones y registros.
3. Aplicar las salvaguardias IGI con los propietarios, procedimientos, métricas de cobertura, excepciones y pruebas.
4. Identidades seguras, configuraciones, vulnerabilidades, correo electrónico, navegadores, defensas de malware, respaldos y monitoreo esencial.
5. Respuesta y recuperación de incidentes de ejercicio antes de una emergencia real.
6. Medir todas las salvaguardias aplicables utilizando insumos fiables y operaciones repetibles.

7. Cobertura incompleta y fallos repetidos; verificar las correcciones mediante el replanteamiento.
8. Ampliar hacia IG2 o IG3 sobre la base de riesgos, obligaciones, madurez y exposición a amenazas.
9. Utilizar mapas oficiales para coordinar otros marcos sin tratar las asignaciones como cumplimiento automático.

tención **Principio de aplicación:** Un grupo más pequeño de Salvaguardias que es totalmente abarcado, operado, medido y mejorado es más defensible que una larga lista marcada completa sin pruebas fiables. | . |

6. Control 1 - Inventario y Control de Activos Empresarios

Las 5 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

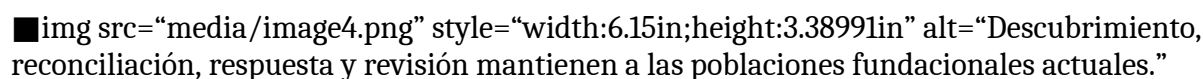
■  src="media/image4.png" style="width:6.15in;height:3.38991in" alt="Descubrimiento, reconciliación, respuesta y revisión mantienen a las poblaciones fundacionales actuales.”

Figure 4. Asset and software inventory cycle

**** Objetivo de control:** ** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para el inventario y el control de los activos institucionales. |

| ... |

1.1

1.2

1.3

1.4

Ø 1.5 Ø Utilizar una herramienta de descubrimiento de activos pasivos Ponga en marcha un proceso repetible, de propiedad o control técnico para utilizar una herramienta Passive Asset Discovery Tool, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de activos, propietarios, estado de aprobación, descubrimiento activo/pasivo, registros DHCP/IPAM, entradas de activos no autorizados

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

7. Control 2 - Inventario y control de activos de software

Las 7 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:**** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para el inventario y el control de los activos informáticos. |

| ... |

TEN 2.1

2.2

2.3

2.4

2.5 Silencioso Software autorizado Ponga en marcha un proceso repetible, de propiedad o control técnico para permitir el Software Autorizado, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de software, estado de apoyo, lista aprobada, resultados de descubrimientos, excepciones, políticas de habilitación y eventos

2.6

2.7

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

8. Control 3 - Protección de datos

Todas las 14 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

'img src="media/image5.png" style="width:6.15in;height:3.39605in" alt="Descubrir, clasificar, proteger, retener y disponer de datos de acuerdo a la sensibilidad y la necesidad."

Gráfico 5 Ciclo de vida de protección de datos

**** Objetivo de control:**** Fortalecer la empresa mediante la aplicación y medición de salvaguardias para la protección de datos. |

| ... |

TEN 3.1

TEN 3.2

3.3

TEN 3.4 TENCIÓN DE LOS RECURSOS DE EJECUCIÓN DE LOS Datos TENIENTES Ponga en marcha un proceso repetible, de propiedad o control técnico para hacer cumplir la Retención de Datos, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y

registros de acceso TENCIÓN 3.5 TENIENDO EL DISPONIBLE DE LOS Datos Ponga en marcha un proceso repetible, de propiedad o control técnico para disponer de datos de forma segura, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso tención 3.6 – Encrypt Data on End-User Devices tención Ponga en marcha un proceso repetible, de propiedad o control técnico para cifrar datos sobre dispositivos de usuario final, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso | 3.7 | Establecer y mantener un plan de clasificación de datos | Poner en marcha un proceso de repetición, propiedad o control técnico para establecer y mantener un plan de clasificación de datos, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso | 3.8 | Document Data Flows | Ponga en marcha un proceso repetible, de propiedad o control técnico para documentar los flujos de datos, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso TEN 3.9 | Datos de cifrado en medios extraíbles ANTEPonga un proceso repetible, de propiedad o control técnico en su lugar para cifrar datos en medios extraíbles, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso | 3.10 | Encrypt Sensitive Data in Transit – Ponga en marcha un proceso repetible, de propiedad o control técnico para cifrar datos sensibles en tránsito, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso | 3.11 | Encrypt Sensitive Data At Rest Ponga en marcha un proceso repetible, de propiedad o control técnico para cifrar datos sensibles en reposo, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso | 3.12 | Segment Data Processing and Storage Based on Sensitivity TEN Poner en marcha un proceso repetible, de propiedad o control técnico para segmentar el procesamiento de datos y almacenamiento basado en la sensibilidad, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso | 3.13 | Implementar una solución de prevención de la pérdida de datos Ponga en marcha un proceso repetible, de propiedad o control técnico para desplegar una solución de prevención de la pérdida de datos, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso | 3.14 |

Log Sensitive Data Access Ponga en marcha un proceso repetible, de propiedad o control técnico para registrar el acceso de datos sensibles, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de datos, clasificación, flujos, LCA, retención, eliminación, encriptación, DLP y registros de acceso

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

9. Control 4 — Configuración segura de activos y software empresarial

Las 12 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:**** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la configuración segura de los activos y programas institucionales. |

|... |

Ø 4.1 tención Establecer y mantener un proceso de configuración segura — Poner en marcha un proceso repetible, de propiedad o control técnico para establecer y mantener un proceso de configuración segura, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil Ø 4.2 tención Establecer y mantener un proceso de configuración segura para infraestructura de red — Poner en marcha un proceso repetible, de propiedad o control técnico para establecer y mantener un proceso de configuración segura para infraestructura de red, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil | 4.3 | Configure Automatic Session Locking on Enterprise Assets — Ponga en marcha un proceso repetible, de propiedad o control técnico para configurar el bloqueo automático de sesión en activos empresariales, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil | 4.4 — Implementar y administrar un cortafuegos en servidores — Poner en marcha un proceso repetible, de propiedad o control técnico para implementar y administrar un cortafuegos en servidores, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil | | 4.5 — Implementar y administrar un cortafuegos en dispositivos de usuario final — Poner en marcha un proceso

repetible, de propiedad o control técnico para implementar y administrar un cortafuegos en dispositivos de usuario final, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil | | 4.6 | Gestionar de forma segura los activos y el software de la empresa – Poner en marcha un proceso repetible, propiedad o control técnico para gestionar de forma segura los activos y software de la empresa, a continuación, verificar la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil | 4.7 | Manage Default Accounts on Enterprise Assets and Software tención Ponga en marcha un proceso repetible, de propiedad o control técnico para gestionar Cuentas Predeterminadas en Activos y Software Empresarial, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil | 4.8 | Desinstalar o desactivar servicios innecesarios en activos y software de la empresa | Ponga un proceso repetible, propiedad o control técnico en su lugar para desinstalar o desactivar servicios innecesarios en activos y software de la empresa, a continuación, verifique la cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil | 4.9 | Configure Trusted DNS Servers on Enterprise Assets tención Ponga en marcha un proceso repetible, de propiedad o control técnico para configurar Trusted DNS Servers on Enterprise Assets, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil | 4.10 | Enforce Automatic Device Lockout on Portable End-User Devices Ponga en marcha un proceso repetible, de propiedad o control técnico para hacer cumplir el bloqueo automático de dispositivos en dispositivos portátiles de usuario final, a continuación, verifique la cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil | | 4.11 | Enforce Remote Wipe Capability on Portable End-User Devices Ponga en marcha un proceso repetible, de propiedad o control técnico para hacer cumplir la Capacidad de Wipe remota en dispositivos portátiles de usuario final, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil | 4.12 – Espacios de trabajo para empresas separadas en dispositivos móviles de usuario final TENIENDO un proceso repetible, de propiedad o control técnico en el lugar para separar espacios de trabajo empresariales en dispositivos móviles de usuario final, luego verificar

cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. estándares de configuración, resultados de referencia, cortafuegos, cerraduras de sesión, protocolos de administración, predeterminados, servicios y configuración móvil |

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

Control 5 - Gestión de Cuentas

Todas las 6 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:**** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la gestión de las cuentas. |

|. |

5.1

TEN 5.2

5.3

tención 5.4 Silencioso Administrador de Restricciones Privilegios a Cuentas Administradoras Dedicadas Poner en marcha un proceso repetible, de propiedad o control técnico para restringir los privilegios del Administrador a las Cuentas de Administrador Dedicado, a continuación, verificar la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. poblaciones, propietarios, fechas, política de contraseñas, acciones de cuenta inactiva, inventarios de administración y de cuenta de servicios TEN 5.5 | Establecer y mantener un inventario de cuentas de servicio | Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener un inventario de cuentas de servicio, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. poblaciones, propietarios, fechas, política de contraseñas, acciones de cuenta inactiva, inventarios de administración y de cuenta de servicios | 5.6 | Centralizar Gestión de Cuentas Poner en marcha un proceso repetible, de propiedad o control técnico para centralizar la gestión de cuentas, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. poblaciones, propietarios, fechas, política de contraseñas, acciones de cuenta inactiva, inventarios de administración y de cuenta de servicios

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

11. Control 6 — Access Control Management

Las 8 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

img src="media/image6.png" style="width:6.15in;height:3.03192in" alt="Las cuentas y privilegios requieren la creación aprobada, la autenticación fuerte, la revisión y la revocación oportuna".

Gráfico 6 Identidad y acceso ciclo de vida

**** Objetivo de control:**** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la gestión del control del acceso. |

|... |

TEN 6.1 TEN Establezca un proceso de concesión de acceso

6.2

TEN 6.3

6.4

tención 6.5 Silencioso Consultar MFA para el acceso administrativo Poner en marcha un proceso repetible, de propiedad o control técnico para exigir el MFA de Acceso Administrativo, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso | 6.6 | Establecer y mantener un inventario de sistemas de autenticación y autorización | Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener un inventario de sistemas de autenticación y autorización, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso | 6.7 | Centralizar control de acceso Ponga en marcha un proceso repetible, de propiedad o control técnico para centralizar el control de acceso, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso | 6.8 | Definir y mantener el control de acceso basado en roles Ponga en marcha un proceso repetible, de propiedad o control técnico para definir y mantener el control de acceso basado en roles, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. Entradas de subvención/revocación, cobertura del MFA, inventario del sistema de autenticación, funciones, derechos y exámenes de acceso

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

Control 7 - Gestión continua de la vulnerabilidad

Las 7 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

■img src="media/image7.png" estilo="width:6.15in;height:3.14547in" alt="Cobertura completa y materia de remediación verificada más que producir informes de escaneo." /

Gráfico 7 Gestión continua de la vulnerabilidad

**** Objetivo de control:**** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la gestión continua de la vulnerabilidad. |

|... |

7.1

TEN 7.2

7.3

7.4 ▶ Perform Automated Application Patch Management Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar Automated Application Patch Management, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. procesos, alimentaciones, cobertura de activos, escaneos autenticados, resultados de parches, excepciones, boletos de remediación y rescans

7.5

TEN 7.6 ANTE Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets
TEN Ponga en marcha un proceso repetible, de propiedad o control técnico para realizar escáneres de vulnerabilidad automatizados de activos de empresas externamente expuestas, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. procesos, alimentaciones, cobertura de activos, escaneos autenticados, resultados de parches, excepciones, boletos de remediación y rescans | 7.7 | Remediate Detected Vulnerabilities – Poner en marcha un proceso repetible, de propiedad o control técnico para remediar Vulnerabilidades Detectadas, luego verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. procesos, alimentaciones, cobertura de activos, escaneos autenticados, resultados de parches, excepciones, boletos de remediación y rescans

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

13. Control 8 — Audit Log Management

Las 12 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:** **** Fortalecer la empresa mediante la aplicación y medición de salvaguardias para la gestión de registros de auditoría. |**

| ... |

tención 8.1

8.2

8.3

8.4 – Normalizar la sincronización del tiempo – Poner en marcha un proceso repetible, de propiedad o control técnico para estandarizar la sincronización del tiempo, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. requisitos de registro, inventario de fuentes, almacenamiento, configuración del tiempo, registros detallados, plataforma central, revisiones y retención

8.5

8.6

8.7

8.8

8.9

8.10

8.11

8.12

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

14. Control 9 - Protección de correo electrónico y navegador web

Las 7 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:** **** Fortalecer la empresa mediante la implementación y medición de salvaguardias para las protecciones de correo electrónico y navegador web. |**

Respuesta

TEN 9.1 TENCIÓN Asegurar el uso de sólo navegadores completos y clientes de correo electrónico

TEN 9.2

9.3

9.4

TEN 9.5

TEN 9.6

9.7

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

15. Control 10 — Malware Defenses

Las 7 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:** Fortalecer la empresa mediante la implementación y medición de salvaguardias para defensas de malware. |

|... |

10.1

10.2

TEN 10.3

10.4

10.5

10.6

10.7

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

16. Control 11 — Data Recovery

Las 5 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:** Fortalecer la empresa mediante la aplicación y medición de salvaguardias para la recuperación de datos. |

|... |

TEN 11.1

11.2

11.3

TEN 11.4

TEN 11.5

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

Control 12 - Gestión de la infraestructura de red

Las 8 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:**** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la gestión de la infraestructura de red. |

Respuesta

**** | **** Salvaguardia**** | **Significado claro** | **** Enfoque de la verificación****

|

—- Enviado | | 12.1 | Garantizar que la infraestructura de red esté actualizada Ponga en marcha un proceso repetible, de propiedad o control técnico para asegurar que la infraestructura de red esté actualizada, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración | 12.2 | Establecer y mantener una arquitectura de red segura – Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener una arquitectura de red segura, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración | 12.3 – Gestión segura de la infraestructura de red Ponga en marcha un proceso repetible, de propiedad o control técnico para gestionar de forma segura la infraestructura de red, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración | TEN 12.4 | Establecer y mantener los diagramas de arquitectura | Poner en marcha un proceso repetible, propiedad o control técnico para establecer y mantener los diagramas de arquitectura, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones,

corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración | 12.5 | Centralizar Autenticación, Autorización y Auditoría de la Red | Poner en marcha un proceso repetible, de propiedad o control técnico para centralizar la autenticación, Autorización y Auditoría de la Red, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración TEN 12.6 | Utilizar protocolos de gestión y comunicación de redes seguras Ponga en marcha un proceso repetible, de propiedad o control técnico para utilizar protocolos de gestión y comunicación de redes seguras, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración | 12.7 | Garantizar dispositivos remotos Utilice una VPN y Enterprise AAA | Ponga en marcha un proceso repetible, de propiedad o control técnico para asegurar dispositivos remotos Use una VPN y Enterprise AAA, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración | 12.8 | Mantener los recursos de computación dedicados para el trabajo administrativo Poner en marcha un proceso repetible, de propiedad o control técnico para mantener los Recursos de Computación Dedicada para el Trabajo Administrativo, a continuación, verificar cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario de red, versiones, arquitectura, diagramas, vías de administración, AAA, protocolos seguros, VPN y estaciones de trabajo de administración

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

18. Control 13 — Network Monitoring and Defense

Todas las 11 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

■img src="media/image8.png" estilo="width:6.15in;height:3.20094in" alt="Contexto centralizado, detección sintonizada, investigación humana y respuesta crean defensa útil".

Figure 8. Monitoring-to-response workflow

**** Objetivo de control:**** Fortalecer la empresa mediante la implementación y medición de salvaguardias para el monitoreo y defensa de redes. |

|... |

13.2

13.3

13.4

13.5

13.6 ► Collect Network Traffic Flow Logs Ponga en marcha un proceso repetible, de propiedad o control técnico para recoger los Logs de flujo de tráfico de red, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación

13.7

13.8

13.9 Ponga en marcha un proceso repetible, de propiedad o control técnico para desplegar Port-Level Access Control, a continuación, verifique cobertura y excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. cobertura SIEM, detección de host/network, segmentación, mandos remotos, registros de flujo, sistemas de prevención y alerta de afinación

13.10

13.11

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

19. Control 14 - Capacitación en conciencia de seguridad y habilidades

Las 9 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:** ** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la sensibilización en materia de seguridad y la capacitación en aptitudes. |

|... |

TEN 14.1

14.2

TEN 14.3

14.4

14.5

14.6

14.7

TEN 14.8

TEN 14.9

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

20. Control 15 — Service Provider Management

Las 7 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:**** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la gestión de proveedores de servicios. |

| ... |

TEN 15.1

15.2

15.3 Ponga en marcha un proceso repetible, de propiedad o control técnico para clasificar a los proveedores de servicios, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario, clasificaciones, políticas, contratos, evaluaciones, vigilancia, incidentes y pruebas de descomposición

15.4

15.5 Silenciosos Proveedores de Servicios

15.6 Poner en marcha un proceso repetible, de propiedad o control técnico para supervisar a los proveedores de servicios, verificar la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. inventario, clasificaciones, políticas, contratos, evaluaciones, vigilancia, incidentes y pruebas de descomposición

15.7

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

Control 16 - Seguridad del Software de Aplicación

Todas las 14 Salvaguardias, significado claro, enfoque de verificación y evidencia de ejemplo.

**** Objetivo de control:**** Fortalecer la empresa mediante la aplicación y medición de las salvaguardias para la seguridad de los programas de aplicación. |

| ... |

16.1

16.2

16.3

16.4

16.5 – Utilizar componentes de software de terceros actualizados y confiados Ponga en marcha un proceso repetible, de propiedad o control técnico para utilizar componentes de software de terceros actualizados y confiados, a continuación, verifique la cobertura y las excepciones. tención Confirme alcance definido, población, propiedad, implementación, frecuencia, cobertura, excepciones, corrección y retest. TEN seguro SDLC, proceso de divulgación, causa raíz, inventario de componentes, severidad, endurecimiento, entrenamiento, pruebas y modelos de amenaza

16.6

TEN 16.7

16.8

16.9

16.10

TEN 16.11

16.12

16.13

16.14

Utilice la guía oficial CIS Controls v8.1 y Evaluación de Controles Especificación para el lenguaje exacto de Salvaguardia, clase de activos, función de seguridad, Grupo de Implementación, dependencias, insumos, operaciones, medidas, métricas y revisión procesal.

22. Control 17 — Gestión de la respuesta a incidentes

Las nueve Salvaguardas, su significado en lenguaje claro, el enfoque de verificación y ejemplos de evidencia.

Figura 9. Preparación para la respuesta a incidentes

Objetivo del control: Fortalecer la organización mediante la implementación y medición de Salvaguardas para la gestión de la respuesta a incidentes.

ID	Salvaguarda	Significado en lenguaje claro	Enfoque de verificación	Ejemplos de evidencia
17.1	Designar al personal	Implementar un proceso	Confirmar alcance,	responsables de incidentes,

ID	Salvaguarda	Significado en lenguaje claro	Enfoque de verificación	Ejemplos de evidencia
	responsable de gestionar los incidentes	repetible, con un responsable definido, para designar al personal encargado de gestionar los incidentes; después, verificar su cobertura y sus excepciones.	población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	contactos, mecanismos de reporte, plan, roles, comunicaciones, ejercicios, revisiones y umbrales
17.2	Mantener información de contacto para reportar incidentes de seguridad	Implementar un proceso repetible, con un responsable definido, para mantener la información de contacto utilizada para reportar incidentes de seguridad; después, verificar su cobertura y sus excepciones.	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	responsables de incidentes, contactos, mecanismos de reporte, plan, roles, comunicaciones, ejercicios, revisiones y umbrales
17.3	Mantener un proceso organizacional para reportar incidentes	Implementar un proceso repetible, con un responsable definido, para mantener un proceso organizacional de reporte de incidentes; después, verificar su cobertura y sus excepciones.	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	responsables de incidentes, contactos, mecanismos de reporte, plan, roles, comunicaciones, ejercicios, revisiones y umbrales
17.4	Establecer y	Implementar un	Confirmar	responsables de

ID	Salvaguarda	Significado en lenguaje claro	Enfoque de verificación	Ejemplos de evidencia
	mantener un proceso de respuesta a incidentes	proceso repetible, con un responsable definido, para establecer y mantener un proceso de respuesta a incidentes; después, verificar su cobertura y sus excepciones.	alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	incidentes, contactos, mecanismos de reporte, plan, roles, comunicaciones, ejercicios, revisiones y umbrales
17.5	Asignar roles y responsabilidad es clave	Implementar un proceso repetible, con un responsable definido, para asignar roles y responsabilidad es clave; después, verificar su cobertura y sus excepciones.	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	responsables de incidentes, contactos, mecanismos de reporte, plan, roles, comunicaciones, ejercicios, revisiones y umbrales
17.6	Definir mecanismos de comunicación durante la respuesta a incidentes	Implementar un proceso repetible, con un responsable definido, para definir mecanismos de comunicación durante la respuesta a incidentes; después, verificar su cobertura y sus excepciones.	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	responsables de incidentes, contactos, mecanismos de reporte, plan, roles, comunicaciones, ejercicios, revisiones y umbrales
17.7	Realizar ejercicios periódicos de	Implementar un proceso repetible, con un	Confirmar alcance, población,	responsables de incidentes, contactos,

ID	Salvaguarda	Significado en lenguaje claro	Enfoque de verificación	Ejemplos de evidencia
	respuesta a incidentes	responsable definido, para realizar ejercicios periódicos de respuesta a incidentes; después, verificar su cobertura y sus excepciones.	responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	mecanismos de reporte, plan, roles, comunicaciones, ejercicios, revisiones y umbrales
17.8	Realizar revisiones posteriores a los incidentes	Implementar un proceso repetible, con un responsable definido, para realizar revisiones posteriores a los incidentes; después, verificar su cobertura y sus excepciones.	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	responsables de incidentes, contactos, mecanismos de reporte, plan, roles, comunicaciones, ejercicios, revisiones y umbrales
17.9	Establecer y mantener umbrales para los incidentes de seguridad	Implementar un proceso repetible, con un responsable definido, para establecer y mantener umbrales para los incidentes de seguridad; después, verificar su cobertura y sus excepciones.	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	responsables de incidentes, contactos, mecanismos de reporte, plan, roles, comunicaciones, ejercicios, revisiones y umbrales

Utilice la guía oficial de CIS Controls v8.1 y la Especificación para la Evaluación de Controles para consultar el lenguaje exacto de cada Salvaguarda, la clase de activo, la función de seguridad, el Grupo de Implementación, las dependencias, las entradas, las operaciones, las medidas, las métricas y la revisión de procedimientos.

23. Control 18 — Pruebas de penetración

Las cinco Salvaguardas, su significado en lenguaje claro, el enfoque de verificación y ejemplos de evidencia.

Objetivo del control: Fortalecer la organización mediante la implementación y medición de Salvaguardas para las pruebas de penetración.

ID	Salvaguarda	Significado en lenguaje claro	Enfoque de verificación	Ejemplos de evidencia
18.1	Establecer y mantener un programa de pruebas de penetración	Implementar un proceso repetible, con un responsable definido, para establecer y mantener un programa de pruebas de penetración; después, verificar su cobertura y sus excepciones.	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	reglas de compromiso aprobadas, alcance, evaluadores cualificados, informes, remediación, repetición de pruebas y evidencia de validación
18.2	Realizar pruebas periódicas de penetración externa	Implementar un proceso repetible, con un responsable definido, para realizar pruebas periódicas de penetración externa; después, verificar su cobertura y sus excepciones.	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	reglas de compromiso aprobadas, alcance, evaluadores cualificados, informes, remediación, repetición de pruebas y evidencia de validación
18.3	Corregir los hallazgos de las pruebas de penetración	Implementar un proceso repetible, con un responsable definido, para corregir los hallazgos de las pruebas de	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones,	reglas de compromiso aprobadas, alcance, evaluadores cualificados, informes, remediación,

ID	Salvaguarda	Significado en lenguaje claro	Enfoque de verificación	Ejemplos de evidencia
		penetración; después, verificar su cobertura y sus excepciones.	corrección y repetición de pruebas.	repetición de pruebas y evidencia de validación
18.4	Validar las medidas de seguridad	Implementar un proceso repetible, con un responsable definido, para validar las medidas de seguridad; después, verificar su cobertura y sus excepciones.	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	reglas de compromiso aprobadas, alcance, evaluadores cualificados, informes, remediación, repetición de pruebas y evidencia de validación
18.5	Realizar pruebas periódicas de penetración interna	Implementar un proceso repetible, con un responsable definido, para realizar pruebas periódicas de penetración interna; después, verificar su cobertura y sus excepciones.	Confirmar alcance, población, responsabilidad, implementación, frecuencia, cobertura, excepciones, corrección y repetición de pruebas.	reglas de compromiso aprobadas, alcance, evaluadores cualificados, informes, remediación, repetición de pruebas y evidencia de validación

Utilice la guía oficial de CIS Controls v8.1 y la Especificación para la Evaluación de Controles para consultar el lenguaje exacto de cada Salvaguarda, la clase de activo, la función de seguridad, el Grupo de Implementación, las dependencias, las entradas, las operaciones, las medidas, las métricas y la revisión de procedimientos.

24. Herramientas de código abierto

Enlaces oficiales, inicios rápidos seguros, evidencia y limitaciones.

Herramienta	Propósito	Controles posibles
CIS Controls Navigator	Seleccionar Grupos de Implementación y explorar	Todos

Herramienta	Propósito	Controles posibles
	correspondencias oficiales	
CIS Controls Assessment Specification	Orientación oficial para la medición	Todos
CIS-CAT Lite	Evaluación de determinados CIS Benchmarks	4
CISO Assistant	Controles, riesgos, evidencia y hallazgos	Todos
Wazuh	Monitoreo de endpoints, SIEM, FIM y alertas	1, 4, 8, 10, 13, 17
osquery	Consultas sobre activos, software, cuentas y configuración	1, 2, 4, 5, 8
OpenSCAP	Evaluación de configuración segura en Linux	4, 7
Lynis	Auditoría de seguridad en Linux	4, 7
Nmap	Descubrimiento autorizado de activos y servicios	1, 12
Greenbone Community Edition	Evaluación de vulnerabilidades	7
Trivy	Repositorios, imágenes, dependencias, secretos e infraestructura como código	2, 4, 7, 16
OWASP ZAP	Pruebas autorizadas de seguridad web	16, 18
Suricata	Detección de intrusiones en red y visibilidad del tráfico	8, 13, 17
Keycloak	Identidades, roles, MFA, sesiones y eventos	5, 6, 8
DefectDojo	Ingesta de hallazgos, deduplicación, remediación y repetición de pruebas	7, 16, 18
Velociraptor	Visibilidad de endpoints y respuesta a incidentes	1, 8, 13, 17

Limitación crítica: Una herramienta puede respaldar una o más Salvaguardas, pero no puede seleccionar por sí sola el Grupo de Implementación de una organización, definir su tolerancia al riesgo, garantizar una cobertura completa, sustituir los procedimientos y la revisión humana, autorizar pruebas de penetración ni demostrar por sí sola el cumplimiento de otro marco.

25. Manual de los Controles CIS para gerentes

Preguntas, tablero, responsabilidades y decisiones que la dirección debe controlar.

1. ¿El Grupo de Implementación seleccionado sigue siendo apropiado para los datos sensibles, los servicios críticos, la exposición a amenazas, las obligaciones, la escala y las capacidades disponibles?
2. ¿Las poblaciones fundamentales están completas, actualizadas, tienen un responsable y se concilian con fuentes independientes de descubrimiento?
3. ¿Qué Salvaguardas de IG1 presentan cobertura incompleta, revisiones vencidas, datos de entrada poco fiables o excepciones recurrentes?
4. ¿Se escalan el acceso administrativo, los sistemas expuestos externamente, el software sin soporte, las vulnerabilidades críticas y los fallos de recuperación?
5. ¿Las alertas generan investigación y respuesta, o solo volumen en los tableros?
6. ¿Se comprenden las responsabilidades de los proveedores de servicios, la evidencia, las obligaciones ante incidentes, los subcontratistas y los planes de salida?
7. ¿Las pruebas de penetración y los ejercicios están autorizados de forma segura, tienen un alcance adecuado, se realizan con independencia cuando corresponde y se siguen hasta la repetición de pruebas?
8. ¿Qué financiación, personal, tiempo de ingeniería o decisión empresarial está bloqueando la corrección?

Área	Pregunta para la dirección	Estado
IG y alcance	¿Están documentadas la priorización, las adiciones, las exclusiones y las obligaciones?	Verde / Amarillo / Rojo
Inventarios	¿Están completos los activos, el software, los datos, las cuentas, los proveedores, las aplicaciones y los registros?	Verde / Amarillo / Rojo
Protección	¿Funcionan los controles de configuración, acceso, parches, correo electrónico, malware y datos?	Verde / Amarillo / Rojo
Detección	¿La cobertura de registros y red está completa y se revisan las alertas?	Verde / Amarillo / Rojo
Recuperación	¿Las copias de seguridad protegidas y las	Verde / Amarillo / Rojo

Área	Pregunta para la dirección	Estado
	restauraciones se prueban frente a las necesidades del negocio?	
Respuesta	¿Están actualizados los roles, contactos, umbrales, ejercicios y revisiones?	Verde / Amarillo / Rojo
Medición	¿Los datos de entrada son fiables y se corrigen las poblaciones con excepciones?	Verde / Amarillo / Rojo
Aseguramiento	¿Las pruebas, limitaciones, hallazgos y repeticiones de pruebas son sustentables?	Verde / Amarillo / Rojo

26. Guía profesional para analistas junior

Una ruta práctica hacia trabajos de controles, vulnerabilidades, aseguramiento, GRC y operaciones de seguridad.

Figura 10. Ruta para analistas junior de Controles CIS

Analista junior de controles de seguridad

Analista de GRC

Analista de gestión de vulnerabilidades

Analista de aseguramiento de seguridad

Analista de operaciones de seguridad

Analista de cumplimiento de TI

Analista de riesgos de terceros

Analista de programas de ciberseguridad

26.1 Trabajo típico de nivel junior

- Mantener inventarios de activos, software, datos, cuentas, sistemas de red, proveedores, aplicaciones, hallazgos y evidencia.
- Recopilar evidencia sin alterar los registros fuente y validar la integridad de las poblaciones.
- Mapear Salvaguardas con responsables, sistemas, procedimientos, configuraciones, evidencia, métricas, excepciones y acciones.

- Ejecutar herramientas autorizadas de descubrimiento, configuración, vulnerabilidades, registros o seguridad de aplicaciones conforme a procedimientos aprobados.
- Calcular métricas de cobertura y excepciones mediante la estructura oficial de evaluación.
- Dar seguimiento al software sin soporte, activos no autorizados, problemas de acceso, vulnerabilidades, copias de seguridad fallidas, brechas de alertas y hallazgos de proveedores hasta la repetición de pruebas.
- Redactar conclusiones claras sin afirmar autoridad ni certeza más allá de lo que respalda la evidencia.

Competencia	Evidencia para el portafolio
Marco	Explicar los 18 Controles, los IG, las clases de activos y las funciones
Inventarios	Conciliar dos fuentes independientes y explicar las diferencias
Medición	Mostrar entradas, operaciones, medidas, métrica, lista de excepciones y conclusión
Conocimientos técnicos	Interpretar evidencia de configuración, identidad, escaneo, registros, recuperación y aplicaciones
Remediación	Relacionar el hallazgo con el responsable, la fecha límite, la corrección y la repetición de pruebas verificada
Comunicación	Redactar un resumen de una página para la dirección y un documento de trabajo detallado
Ética	Utilizar datos sintéticos, autorización, límites de alcance y afirmaciones honestas

27. Laboratorio y portafolio ficticios

Un entorno seguro de práctica con datos sintéticos y sistemas de laboratorio autorizados.

Regla del laboratorio: Utilice organizaciones ficticias, datos sintéticos, sistemas aislados y autorización escrita. Nunca ataque objetivos públicos, use credenciales reales ni publique resultados sensibles de herramientas.

1. Cree una empresa ficticia de 50 personas con portátiles, servidores, servicios en la nube, una aplicación web, personal remoto y cinco proveedores.
2. Seleccione IG1 y documente tres adiciones basadas en riesgos provenientes de IG2 o IG3.

3. Cree inventarios de activos empresariales, software, datos, cuentas, sistemas de autenticación, red, proveedores, aplicaciones y fuentes de registros.
4. Utilice Nmap y osquery en un laboratorio aislado para conciliar los inventarios de activos y software.
5. Utilice OpenSCAP o Lynis en un equipo de laboratorio; documente hallazgos de configuración, excepciones, correcciones y reevaluación.
6. Utilice Greenbone en objetivos de laboratorio aprobados; valide la cobertura, los hallazgos, la remediación y el nuevo escaneo.
7. Utilice Wazuh o Suricata para generar e investigar una alerta de prueba segura.
8. Utilice Trivy o ZAP sobre un repositorio o una aplicación de capacitación y registre la corrección y la repetición de pruebas.
9. Redacte una prueba de restauración de copias de seguridad y un registro de ejercicio de mesa para incidentes.
10. Cree cinco documentos de trabajo basados en la Especificación para la Evaluación de Controles CIS, con entradas, operaciones, medidas, métricas, listas de excepciones y conclusiones.
11. Publique únicamente artefactos depurados e indique claramente que el proyecto es ficticio y no constituye una evaluación formal de CIS.

Artefacto	Qué demuestra
Memorando de selección del IG	Priorización y razonamiento basado en riesgos
Conciliación de inventarios	Integridad de la población y capacidad analítica
Documento de trabajo de una Salvaguarda	Estructura oficial de medición y evidencia
Reevaluación de configuración	Hallazgo técnico, corrección y repetición de pruebas
Informe de vulnerabilidades	Cobertura, priorización, excepción y remediación
Caso de detección	Validación, investigación y respuesta ante alertas
Prueba de restauración	Evidencia de disponibilidad y recuperación
Tablero para la dirección	Comunicación clara de riesgos y acciones

28. Plan de aprendizaje de treinta días

Un cronograma concentrado para desarrollar capacidades útiles de nivel junior.

Días	Enfoque	Entregable
1-4	Marco, 18 Controles, 153 Salvaguardas, IG, clases de activos y funciones	Mapa conceptual del marco y memorando del IG
5-8	Activos, software, datos, cuentas y acceso	Cuatro inventarios conciliados
9-12	Configuración, vulnerabilidades, correo electrónico y malware	Documento de trabajo de configuración y vulnerabilidades del laboratorio
13-16	Registros, monitoreo y defensa de red	Mapa de fuentes de registros y caso de alerta segura
17-19	Recuperación y respuesta a incidentes	Prueba de restauración y registro de ejercicio de mesa
20-22	Proveedores y seguridad de aplicaciones	Evaluación de proveedor y lista de comprobación de desarrollo seguro
23-25	Especificación para la Evaluación de Controles	Cinco mediciones completas de Salvaguardas
26-28	Laboratorios autorizados con herramientas y remediación	Dos memorandos de corrección y repetición de pruebas
29-30	Portafolio y entrevistas	Portafolio depurado y cinco historias STAR

29.1 ¿Cuáles son los Controles CIS?

Un conjunto priorizado de mejores prácticas defensivas organizadas en 18 Controles y 153 Salvaguardias enfocadas.

29.2 ¿Qué es IG1?

El punto de partida esencial de la higiene cibernética 56-Safeguard que CIS recomienda que cada empresa comience.

29.3 ¿Importa IG1 cada requisito?

Es una base de referencia de priorización. El riesgo material, los contratos, las leyes, los clientes o los servicios críticos pueden requerir salvaguardias adicionales.

29.4 ¿Cómo mide una Salvaguardia?

Utilizar criterios oficiales, dependencias, hipótesis, aportaciones completas, operaciones definidas, medidas, métricas, revisión de procedimientos, excepciones y pruebas.

29.5 ¿Por qué son importantes los inventarios?

Definen a las poblaciones que deben cubrir los controles de configuración, vulnerabilidad, registro, recuperación y respuesta.

29.6 Vulnerability scan versus penetración test?

Un escaneo identifica principalmente debilidades conocidas; la prueba de penetración utiliza el análisis humano calificado y la explotación controlada para evaluar el impacto y la resiliencia.

29.7 ¿Una cartografía de marco demuestra el cumplimiento?

No. Identifica las relaciones, pero la organización debe probar el requisito y la evidencia exacta aplicable.

29.8 ¿Qué puede concluir un analista junior?

Sólo lo que el alcance definido y el soporte de evidencia confiable, con muestreo y limitaciones claramente reveladas.

29.9 Preguntas para hacer al empleador

¿Qué grupo de implementación y adiciones están en alcance?

¿Cómo se crean y reconcilian las poblaciones de inventarios?

¿Qué Salvaguardias tienen la cobertura más incompleta?

¿Cómo se revisan los datos de medición y las excepciones?

¿Qué herramientas de código abierto y comerciales son aprobadas?

¿Cómo se priorizan, financian y prueban los resultados?

¿Cómo revisará el trabajo de los funcionarios superiores?

30. Plantillas, Glosario, Índice y Referencias

- Estructuras de trabajo reutilizables, términos importantes y puntos de partida autorizados.*

30.1 Documentos de trabajo de medición de salvaguardia

|** | |. | “La Salvaguardia de la Vida” y la IG “Antes” “Escopia y clase de activos” “Principal y sistemas de vida” Las dependencias y las suposiciones de la vida Inputs y validación de la vida “Operaciones en la vida” “Las medidas de la vida” “Metric and interpretation |” Excepciones y limitaciones de la vida La acción, el dueño, la fecha y la prueba de la vida

30.2 Registro de hallazgos y nuevas pruebas

|** | |... | Los Criterios de la vida siguen adelante. “Acondicionamiento y evidencia de vida” La población afectada está en peligro. “El riesgo y el impacto en la vida” | Cause TENED | “La protección provisional en la vida” Corrección y propietario de la vida La fecha de su muerte es la siguiente. “El procedimiento de la prueba de mentiras” Resultado final de la vida útil

30.3 Glosario

|** | |. | | Clase Asset | Categoría afectada por una Salvaguardia, como dispositivos, software, datos, red, usuarios o documentación. | | CIS Benchmark – Recomendaciones de configuración segura para una tecnología específica. | tención CIS Control | Una de las 18 amplias áreas defensivas. confidencialidad CIS Salvaguardia | Una acción enfocada y implementable dentro de un Control. – TENCION TENIDA Compartir de la población aplicable en la que se implementa adecuadamente la Salvaguardia. | | IG1 tención 56 salvaguardas esenciales de la higiene cibernética. | | IG2 | IG1 más 74 Salvaguardias adicionales. TENIDA IG3 TENIDA IG1 e IG2 más 23 Salvaguardias adicionales; todos 153. TENCION | Una cuenta, lista, fecha, configuración o resultado producido por operaciones de evaluación. | | | Cálculo o interpretación construido a partir de medidas. | Población | Completo conjunto de registros, activos, personas, sistemas o eventos aplicables. tención Revisión de procedimiento tención Evaluación manual de si existe un proceso necesario y contiene los elementos necesarios. | Función de seguridad permanente – Govern, Identificar, Proteger, Detectar, Responder o Recuperar la cartografía.

30.4 Índice de asunto

Subjeto** |... | Silenciosos Cuentas | para la seguridad de la aplicación | Silencioso inventario de activos Silenciosos registros de auditoría | Protección de datos | | Evidencia y medición | 4 Silenciosos Grupos de Aplicación | Respuesta del incidente | Silencioso analista junior | | | Silencioso Silencioso Silencioso en la Red 17-18 | Herramientas de código abierto | 24 | pruebas de Penetración Silencioso Silencioso de recuperación proveedores de servicios | 20 | Silencioso Inventario de software TEN TERRITORIO TERRITORIO TERRITORIO TEN TERRITORIO DE Vulnerabilidad ANTE LAS 12

30.5 Referencias oficiales

[](<https://www.cisecurity.org/controls/v8-1> Controles v8.1

Nota de Controles CIS

[](<https://www.cisecurity.org/controls/implementation-groups>)

Seguido

Seguido

Seguido

[]u]CIS Controles cartografías y cumplimiento efectuados/u
título](<https://www.cisecurity.org/cybersecurity-tools/mapping-compliance/mapping-and-compliance-with-the-cis-controls>)

Recuerdo final: Cambio de marcos, mapas, herramientas, productos, amenazas, leyes, contratos y riesgos organizativos. Confirme los recursos oficiales actuales y las obligaciones aplicables antes de una aplicación o evaluación reales. |

Respuesta